

CASCADE CIVIC SYSTEMS, INC. — CUST

GrantBridge Platform (SaaS) | FedRAMP Moderate | NIST SP 800-53 F

Control ID	Control Name	Responsibility Model
AC-2	Account Management	Shared
AC-2(3)	Disable Inactive Accounts	Shared
AC-6	Least Privilege	Shared
AC-7	Unsuccessful Logon Attempts	CSP
AC-17	Remote Access	Shared
AT-2	Literacy Training and Awareness	Customer
AU-6	Audit Record Review, Analysis, and Reporting	Shared
CA-7	Continuous Monitoring	CSP
CP-9	System Backup	CSP
IA-2	Identification and Authentication (Organizational Users)	Shared
IA-2(1)	MFA to Privileged Accounts	Shared
IR-6	Incident Reporting	Shared
MP-6	Media Sanitization	Inherited
PE-3	Physical Access Control	Inherited

PL-4	Rules of Behavior	Customer
PS-4	Personnel Termination	Shared
RA-5	Vulnerability Monitoring and Scanning	CSP
SC-8	Transmission Confidentiality and Integrity	CSP
SC-28	Protection of Information at Rest	CSP
SI-4	System Monitoring	CSP

OMER RESPONSIBILITY MATRIX (CRM)

Rev. 5 | Companion to SSP v2.1 | Sample GRC portfolio artifact — fictional company

CSP Responsibility (Cascade Civic Systems)	Customer Responsibility (Agency)
Provides role-based account management capability, automated provisioning APIs, inactivity-based disable at 35 days, and audit logging of all account lifecycle events.	Administers its own tenant users: creates, modifies, and removes agency staff accounts; assigns roles per least privilege; performs periodic account reviews of its own user population.
Automatically disables accounts inactive for 35 days and reports disabled accounts to the agency.	Reviews the monthly inactive-account report and confirms whether disabled accounts should be removed or reinstated.
Defines and enforces the platform role model; restricts each role to the minimum privileges required; prevents privilege escalation outside defined roles.	Assigns the least-privileged role appropriate to each of its users; avoids blanket assignment of the Agency Administrator role.
Enforces account lockout after five consecutive failed attempts within a 15-minute window, with a 30-minute lockout duration.	None. Control is fully implemented by the CSP and is not customer-configurable.
Enforces TLS 1.2+ for all access; requires MFA and session recording for CSP administrative access via bastion.	Enforces its own endpoint and network security posture for agency staff accessing the platform, including managed device requirements where the agency requires them.
Provides GrantBridge-specific platform training materials and role-based administrator documentation.	Delivers general security awareness training to its own workforce per agency policy and federal requirements; tracks completion for its own personnel.
Reviews platform-wide and infrastructure audit records weekly; alerts on defined security events; retains records per AU-11.	Reviews tenant-scoped audit reports for its own user activity, including privilege changes and bulk data exports performed by agency users.
Executes the full ConMon program: monthly authenticated scanning, POA&M maintenance and submission, inventory reconciliation, and annual assessment.	Reviews CSP ConMon deliverables provided through the sponsoring agency and raises questions or risk concerns to the AO.
Performs automated encrypted backups: database point-in-time recovery with a 5-minute RPO plus daily cross-region snapshots.	Determines whether agency retention policy requires data export beyond CSP retention periods and uses the export API accordingly.
Supports SAML 2.0 and OIDC federation to agency identity providers and Login.gov; validates assertions; does not store agency credentials.	Operates its own identity provider, enforces its own password and MFA policy for agency staff, and manages the federation trust configuration on its side.
Enforces phishing-resistant MFA for all CSP privileged accounts and rejects assertions lacking an MFA claim where the agency configures that requirement.	Enforces MFA at its own identity provider for all agency users, particularly those assigned the Agency Administrator role.
Notifies US-CERT and the sponsoring agency ISSO within one hour of incident determination; provides incident details and status updates.	Reports agency-side incidents affecting GrantBridge data (e.g., compromised agency credentials) to the CSP; performs its own internal and external reporting per agency policy.
Confirms inheritance and validates that logical data deletion procedures execute as designed.	None. Physical media sanitization is inherited; agency responsibility is limited to requesting data deletion at contract termination.
Confirms inheritance from the underlying IaaS provider; maintains no physical infrastructure in the boundary.	None for the CSP environment. Agency remains responsible for physical security of its own facilities and endpoints.

Presents platform terms of use at first login and records acceptance with timestamp.	Establishes and enforces Rules of Behavior for its own personnel and ensures staff acknowledge them per agency policy prior to being granted access.
Deprovisions CSP personnel access within four hours of termination; provides the agency an API and administrative interface for immediate user removal.	Removes or disables agency user accounts promptly upon staff termination or role change, per agency policy timelines.
Performs monthly authenticated scanning across infrastructure, OS, web, container, and database layers; remediates per FedRAMP timelines.	May review scan summary results provided through the AO. Agency-initiated scanning or penetration testing of the platform requires prior written authorization from the CSP.
Enforces TLS 1.2+ with FIPS 140-3 validated modules on all external and service-to-service communication; rejects deprecated protocols.	Ensures agency endpoints and browsers support TLS 1.2 or higher; does not proxy traffic in a manner that terminates and downgrades TLS.
Encrypts all data stores at rest using AES-256 with customer-managed KMS keys and annual key rotation.	Classifies the data it uploads and refrains from placing information exceeding the system's Moderate categorization into the platform.
Operates IDS/IPS, host-based monitoring, and file integrity monitoring feeding a 24x7 monitored SIEM.	Monitors its own endpoints and identity provider for indicators affecting agency accounts used to access the platform.

Inherited From	Customer Action Required Before Go-Live	Configuration Guidance Reference
	Designate at least two Agency Administrators and document the internal approval workflow for account creation.	Agency Admin Guide §3.1
	Confirm the agency point of contact who will receive and action the monthly report.	Agency Admin Guide §3.4
	Map internal job functions to GrantBridge roles and document the mapping.	Agency Admin Guide §3.2
	None.	SSP §5 / SCTM
	Confirm whether agency policy requires IP allowlisting; submit ranges if so.	Agency Admin Guide §5.1
	Confirm agency security awareness training program covers staff granted GrantBridge access.	N/A
	Designate the agency role responsible for reviewing tenant audit reports and set a review cadence.	Agency Admin Guide §6.2
	Identify the agency recipient for monthly ConMon deliverables.	SSP §6
	Confirm agency record retention requirements against CSP retention periods.	Agency Admin Guide §7.3
	Complete SSO federation setup and provide IdP metadata; confirm agency MFA policy meets FedRAMP Moderate requirements.	SSO Integration Guide §2
	Enable MFA enforcement at the agency IdP for all users granted GrantBridge access.	SSO Integration Guide §3
	Provide 24x7 agency security contact information and confirm the escalation path.	IR Plan §4
AWS GovCloud (FedRAMP High P-ATO)	None.	AWS CRM
AWS GovCloud (FedRAMP High P-ATO)	None.	AWS CRM

	Confirm agency Rules of Behavior are in place and acknowledged by staff receiving access.	N/A
	Integrate GrantBridge deprovisioning into the agency offboarding checklist or automate via SCIM.	Agency Admin Guide §3.5
	Submit a testing authorization request if the agency intends to conduct independent assessment activity.	Rules of Engagement Template
	Verify agency network appliances do not downgrade or break TLS inspection requirements.	Agency Admin Guide §5.2
	Confirm agency data to be processed does not exceed FIPS 199 Moderate categorization.	SSP §3
	Confirm the agency monitors its IdP for credential compromise affecting GrantBridge users.	N/A

Verification Method
Agency attests during onboarding; CSP reports inactive-account metrics monthly.
Monthly report acknowledgment tracked by CSP.
CSP provides role-assignment report; agency reviews quarterly.
3PAO technical test.
Agency attestation; CSP validates allowlist configuration.
Agency attestation at onboarding and annually.
CSP provides tenant audit export; agency confirms review cadence.
AO review of monthly submissions.
Documented in onboarding record.
CSP validates federation in staging; agency attests to MFA enforcement.
Agency attestation; CSP validates MFA claim presence in assertions.
Contact roster validated at onboarding and annually via tabletop.
Inheritance verified during 3PAO assessment.
Inheritance verified during 3PAO assessment.

Agency attestation at onboarding.
Agency attestation; CSP inactive-account report as compensating detection.
AO review; CSP authorization record.
CSP endpoint configuration test; agency attestation.
Agency attestation at onboarding.
Agency attestation.

RESPONSIBILITY DISTRIBUTION

Counts derived from the Customer Responsibility Matrix tab.

Responsibility Model	Count	% of Documented Controls
CSP	7	35.0%
Shared	9	45.0%
Customer	2	10.0%
Inherited	2	10.0%
TOTAL	20	

Controls requiring agency **17**

What it means for the agency
No agency action required. Cascade Civic Systems implements and evidences the control in full.
Both parties must act. The agency's portion must be implemented and attested before go-live.
The agency implements the control entirely. The CSP provides capability or documentation only.
Control is satisfied by the underlying IaaS provider's authorization; no action by either party.

AGENCY ONBOARDING CHECKLIST

Derived from the 'Customer Action Required Before Go-Live' column. Agency compl

#	Control ID	Action Required
1	AC-2	Designate at least two Agency Administrators and document the internal approval workflow for account creation.
2	AC-2(3)	Confirm the agency point of contact who will receive and action the monthly report.
3	AC-6	Map internal job functions to GrantBridge roles and document the mapping.
4	AC-17	Confirm whether agency policy requires IP allowlisting; submit ranges if so.
5	AT-2	Confirm agency security awareness training program covers staff granted GrantBridge access.
6	AU-6	Designate the agency role responsible for reviewing tenant audit reports and set a review cadence.
7	CA-7	Identify the agency recipient for monthly ConMon deliverables.
8	CP-9	Confirm agency record retention requirements against CSP retention periods.
9	IA-2	Complete SSO federation setup and provide IdP metadata; confirm agency MFA policy meets FedRAMP Moderate requirements.
10	IA-2(1)	Enable MFA enforcement at the agency IdP for all users granted GrantBridge access.
11	IR-6	Provide 24x7 agency security contact information and confirm the escalation path.
12	PL-4	Confirm agency Rules of Behavior are in place and acknowledged by staff receiving access.
13	PS-4	Integrate GrantBridge deprovisioning into the agency offboarding checklist or automate via SCIM.
14	RA-5	Submit a testing authorization request if the agency intends to conduct independent assessment activity.
15	SC-8	Verify agency network appliances do not downgrade or break TLS inspection requirements.
16	SC-28	Confirm agency data to be processed does not exceed FIPS 199 Moderate categorization.
17	SI-4	Confirm the agency monitors its IdP for credential compromise affecting GrantBridge users.

ex.

EXAMPLE: Designate at least two Agency Administrators and docum

letes and returns this sheet prior to production access.

Agency Owner	Completed (Y/N)	Date	Notes

J. Rivera, IT Director

Y

2026-04-02

CUSTOMER RESI

Purpose

Why it matters

CSP

Shared

Customer

Inherited

Onboarding Checklist tab

Related documents

RESPONSIBILITY MATRIX — LEGEND

The CRM makes the shared responsibility model explicit. A FedRAMP authorization covers the CSP's controls; it does not make the customer agency automatically compliant. This document tells the agency exactly what it must do.

The most common source of cloud security failures is not a CSP control failure but a customer-side control the agency assumed the CSP was handling. The CRM eliminates that ambiguity in writing before go-live.

Cascade Civic Systems implements and evidences the control in full. No agency action.

Both parties hold a portion of the control. Neither side is compliant unless both portions are implemented.

The agency implements the control entirely; the CSP provides capability, documentation, or configuration options only.

Satisfied by the underlying IaaS provider under its own FedRAMP authorization; documented for traceability, no action by either party.

Extracts every pre-go-live agency action into a sign-off sheet returned to the CSP before production access is granted.

System Security Plan v2.1 (§5 Control Implementation Approach) | SCTM | POA&M | Security Assessment Report